DFIR Investigation Report: TryHackMe Boogeyman 2

Case ID: case-001-thm-boogeyman
Incident type: Phishing with malicious macro document, followed by second-stage execution
Affected host: WKSTN-2961 (Windows workstation, user maxine.beck)
Analysis host: Ubuntu
Verdict: Confirmed malicious document-led execution; persistence plausible but unverified
Confidence: High for execution chain; medium for persistence

1. Executive Summary

A Human Resources specialist at Quick Logistics LLC received a job application email with a Word attachment, *Resume_WesleyTaylor.doc*. The document contains a VBA `AutoOpen` macro that downloads a remote file, saves it as `C:\ProgramData\update.js`, and runs it with `wscript.exe`.

Memory analysis of the workstation corroborates this chain: Outlook opened the email, spawned Word with the cached attachment, Word's descendant `wscript.exe` ran `update.js`, and `updater.exe` then started from `C:\Windows\Tasks\`. Memory strings also contain a command that would create a daily scheduled task named *Updater*, which runs hidden PowerShell that executes code stored in a registry value.

Impact established: Execution of the macro script stage and a second-stage executable on one workstation.
Not established: The function of `updater.exe`, successful persistence, data theft, lateral movement, and the identity of any command-and-control server.

2. Scope and Evidence

This report is based on a TryHackMe lab (Boogeyman 2). The scenario: Maxine Beck, an HR specialist at Quick Logistics LLC, received a job application whose attached resume was malicious and compromised her workstation. Artifacts were downloaded from the room's virtual machine.

#	File name	Type	Size	SHA-256
1	Application for IT Analyst Role.eml	Email (.eml)	103K	88d7090d0a9f7115ce9f76a2c82f6d4843cdf655fba09e0f0c50e4eddd554fce
2	Resume_WesleyTaylor.doc	Word document (.doc)	63K	4db25ee3c46be38aa219fe2192711af65d55d5d7e25a889bb9990beb19f9b8b0
3	WKSTN-2961.raw	Memory image (.raw)	1000M	c0daf36eac4d1d2ff1a328bec21bcf73a2b3c958735d127319a1552d75dc9266

3. Investigation Findings

3.1 Email Analysis

Field	Observed value
Subject	Resume - Application for Junior IT Analyst Role
Sender	westaylor23@outlook.com
Recipient	maxine.beck@quicklogisticsorg.onmicrosoft.com
Displayed applicant	Wesley Taylor
Timestamp	2023-08-20 18:19:20 UTC
Attachment	Resume_WesleyTaylor.doc (64,000 bytes declared)
Sending infrastructure	Microsoft Outlook / Exchange Online
Authentication	SPF, DKIM and DMARC passed
Spam classification	Not flagged as spam in the shown headers
Format	multipart/mixed, containing multipart/alternative and a Word attachment

Assessment: The message fits a job-application lure. Passing authentication only shows the message genuinely originated from the Outlook.com sender domain; it does not indicate the content is benign. The sender account appears to be a free webmail account used to deliver the lure.

3.2 Attachment Analysis

Static analysis with olevba 0.60.2 identified a VBA macro that downloads a remote resource, writes the response to disk, and executes it.

Attribute	Value
Filename	Resume_WesleyTaylor.doc
Macro stream	Macros/VBA/NewMacros
Entry point	AutoOpen
Remote URL	https://files.boogeymanisback.lol/aa2a9c53cbb80416d3b47d85538d9971/update.png
Target path	C:\ProgramData\update.js
Execution utility	wscript.exe

The URL ends in `.png`, but the response is saved as `.js`, which indicates deliberate disguise of the payload type.

3.3 Memory Forensics

3.3.1 Email and attachment opening

- Outlook (PID 1440) started at 14:09:04 UTC on 2023-08-21 with the command line referencing `C:\Users\maxine.beck\Desktop\Resume - Application for Junior IT Analyst Role.eml`.
- Outlook spawned Word (PID 1124) at 14:12:31 UTC. Its command line references the cached attachment `C:\Users\maxine.beck\AppData\Local\Microsoft\Windows\INetCache\Content.Outlook\WQHGZCFI\Resume_WesleyTaylor (002).doc`.

This confirms the email and its attachment were opened on the captured workstation.

3.3.2 Process execution chain

`explorer.exe (596) -> OUTLOOK.EXE (1440) -> WINWORD.EXE (1124) -> wscript.exe (4260) -> updater.exe (6216) -> conhost.exe (4464)`

- 14:12:47 UTC: `wscript.exe` launched `C:\ProgramData\update.js`, matching the macro's target path.
- 14:12:48 UTC: `updater.exe` started from `C:\Windows\Tasks\updater.exe` as a child of `wscript.exe`.
- 14:14:03 UTC: `conhost.exe` started as a child of `updater.exe`.

Assessment: The matching macro, command line, and parent-child relationships strongly corroborate execution of the script stage and a subsequent executable stage.

3.3.3 Network artifacts

Process	Local endpoint	Remote endpoint	State	Time (UTC)
WINWORD.EXE (1124)	10.10.49.181:63243	20.189.173.10:443	CLOSED	14:12:39
svchost.exe (420)	10.10.49.181:63286	20.54.36.229:443	ESTABLISHED	14:14:07
svchost.exe (388)	10.10.49.181:3389	10.4.29.242:63005	ESTABLISHED	14:06:14

- The Word connection occurred just before `wscript.exe` ran and is consistent with the macro download, but nothing in the output ties 20.189.173.10 to `files.boogeymanisback.lol`.
- The `svchost.exe` connections are not attributed to the malware. Port 443 alone does not indicate malicious traffic.
- The inbound session on port 3389 (RDP) from 10.4.29.242 predates the email being opened. It is likely lab or administrative access but should be attributed through service-level and authentication logs.

3.3.4 Memory region in updater.exe

`windows.malfind` flagged a region in PID 6216:

Attribute	Value
Address range	0x13e0000 - 0x13effff
Tag	VadS
Protection	PAGE_EXECUTE_READWRITE
Commit charge / private memory	2 / 1

A readable, writable, and executable private region merits inspection, but the reported bytes and disassembly were inconclusive. This does not on its own establish injection or shellcode.

3.3.5 Loaded modules

`windows.dlllist` shows `updater.exe` (`C:\Windows\Tasks\updater.exe`) loaded:

- **.NET runtime:** MSCOREE.DLL, clr.dll, mscorlib.ni.dll
- **Networking:** WS2_32.dll, winhttp.dll, DNSAPI.dll, IPHLPAPI.DLL
- **PowerShell:** System.Management.Automation.ni.dll, Microsoft.PowerShell.Commands.Utility.ni.dll, Microsoft.PowerShell.Commands.Management.ni.dll
- **WMI:** System.Management.ni.dll and related components
- **Defender-related:** MpOav.dll

This suggests a .NET executable with networking, PowerShell hosting, and WMI capability. Module presence alone does not prove any specific command or request occurred.

3.3.6 File-system artifacts

`windows.filescan` references: the cached attachment `Resume_WesleyTaylor (002).doc`, `\Windows\Tasks\updater.exe`, and the Prefetch file `\Windows\Prefetch\UPDATER.EXE-F25601BD.pf`. These corroborate the process-output paths, but file-scan entries do not show file contents or full execution history.

3.3.7 Scheduled-task persistence indicators

A string search of the memory image found this command:

```
schtasks /Create /F /SC DAILY /ST 09:00 /TN Updater /TR
'C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -NonI -W hidden -c "IEX
([Text.Encoding]::UNICODE.GetString([Convert]::FromBase64String((gp
HKCU:\Software\Microsoft\Windows\CurrentVersion debug).debug)))"'
```

An accompanying string states: *Schtasks persistence established using listener http stored in HKCU:\Software\Microsoft\Windows\CurrentVersion\debug with Updater daily trigger at 09:00.*

Characteristic	Value
Task name	Updater
Trigger	Daily at 09:00

Characteristic	Value
Action	powershell.exe, non-interactive, hidden window
Registry source	HKCU:\Software\Microsoft\Windows\CurrentVersion, value `debug`
Behavior	Reads the value, Base64-decodes it as Unicode text, and runs it with `IEX`

This design keeps the payload in the registry rather than in the task definition, allowing recurring execution of stored commands. Other `schtasks` fragments (create, run, delete) were also present; their relationship to the *Updater* task is not established.

Evidence qualification: The strings show the commands exist in memory. They do not prove the task was registered, the registry value exists, or the task ever ran.

4. Incident Timeline

All times are UTC. The email header date (2023-08-20) differs from the memory-image activity date (2023-08-21) and the two are kept distinct.

Date / time	Event	Basis
2023-08-20 18:19:20	Phishing email sent to Maxine Beck	Observed (email headers)
2023-08-21 14:06:14	Inbound RDP session (10.4.29.242 to port 3389) recorded	Observed (netstat); unattributed
14:09:04	Outlook starts with the suspicious email	Observed
14:12:31	Word starts with the cached attachment	Observed
14:12:39	Word TCP connection to 20.189.173.10:443	Observed; likely macro download (inferred)
14:12:47	`wscript.exe` launches `C:\ProgramData\update.js`	Observed
14:12:48	`updater.exe` starts from `C:\Windows\Tasks\`	Observed
14:14:00 - 14:14:02	PowerShell and WMI-related modules loaded	Observed
14:14:03	`conhost.exe` starts under `updater.exe`	Observed
14:14:07	`svchost.exe` (PID 420) connection to 20.54.36.229:443	Observed; attribution unconfirmed
14:14:25	`DumpIt.exe` starts (memory acquisition)	Observed
Unknown	*Updater* scheduled task created	Not established; string evidence only

5. Indicators of Compromise

Confirmed or strongly supported

Type	Indicator	Evidence
Email sender	westaylor23@outlook.com	Email headers
Email subject	Resume - Application for Junior IT Analyst Role	Email headers
File	Resume_WesleyTaylor.doc, SHA-256 `4db25ee3...f9b8b0`	Static analysis; hash in section 2
Cached file	Resume_WesleyTaylor (002).doc	Word command line, file scan
URL	https://files.boogeymanisback.lol/aa2a9c53cbb80416d3b47d85538d9971/update.png	VBA macro
Domain	files.boogeymanisback.lol	VBA macro
Script path	C:\ProgramData\update.js	VBA macro, `wscript.exe` command line
Executable	C:\Windows\Tasks\updater.exe	Process tree, file scan
Prefetch	C:\Windows\Prefetch\UPDATER.EXE-F25601BD.pf	File scan

Unverified leads

Type	Indicator	Why unverified
Scheduled task	Updater	Command string found; registration not confirmed
Registry	HKCU\Software\Microsoft\Windows\CurrentVersion, value `debug`	Referenced in command string only
IP	20.189.173.10:443	Word-owned connection; not linked to the macro URL
IP	20.54.36.229:443	`svchost.exe` connection; no incident link
IP	10.4.29.242	Inbound RDP source; likely benign lab/admin access

6. MITRE ATT&CK Mapping

Tactic	Technique	Supporting artifact	Confidence
Initial Access	T1566.001 Phishing: Spearphishing Attachment	Email with Word attachment	High
Execution	T1204.002 User Execution: Malicious File	Outlook to Word with cached attachment	High
Execution	T1059.005 Command and Scripting Interpreter: Visual Basic	`AutoOpen` macro (olevba)	High
Execution	T1059.007 Command and Scripting Interpreter: JavaScript	`wscript.exe` running `update.js`	High
Command and Control	T1105 Ingress Tool Transfer	Macro downloads remote content to disk	Medium (download not directly observed)
Defense Evasion	T1036 Masquerading	`.png` URL saved as `.js`; `updater.exe` name	Medium
Persistence	T1053.005 Scheduled Task/Job: Scheduled Task	`schtasks` command string	Low (unverified)
Execution	T1059.001 Command and Scripting Interpreter: PowerShell	Scheduled-task command string; loaded PowerShell modules	Low (unverified)
Defense Evasion	T1027 Obfuscated Files or Information / T1112 Modify Registry	Base64 payload read from registry value	Low (unverified)

7. Verdict and Impact Assessment

Verdict: Confirmed execution of a malicious document-led chain on WKSTN-2961.

Supported by evidence:

- A malicious email with a macro-enabled attachment was opened by the user.
- The macro's script stage ran (`wscript.exe` on `update.js`) and led to a second-stage executable (`updater.exe`).
- Scheduled-task persistence is described in memory and is plausible, but is not verified.

Not established:

- What `updater.exe` actually did, and whether the RWX region held injected code.
- Whether the *Updater* task or the `debug` registry value exists.

- Command-and-control infrastructure, data access or exfiltration, credential theft, or lateral movement.
- Attribution of the observed network connections, including the RDP session.

The evidence supports **confirmed execution** on one host. It does not by itself support a finding of broader compromise.

8. Recommended Actions

Containment

- Isolate WKSTN-2961 from the network and preserve it for forensics.
- Block `files.boogeymanisback.lol` and the sender address at the proxy, DNS, and mail gateway; search mail logs for other recipients of the same message or attachment hash.
- Review the source of the 10.4.29.242 RDP session and restrict RDP exposure.

Investigation (to close open questions)

- Examine `NTUSER.DAT` for the `debug` value under `Software\Microsoft\Windows\CurrentVersion`.
- Check scheduled-task artifacts (task files, TaskCache registry keys) to confirm whether *Updater* was registered, and correlate timestamps.
- Recover `updater.exe` and the RWX memory region from the image and analyze their functionality in an isolated environment.
- Review PowerShell logs and command history.
- Correlate DNS, proxy, firewall, or packet-capture data before attributing any network connection to the malware.

Eradication and recovery

- Remove `update.js`, `updater.exe`, any *Updater* task, and the `debug` registry value once evidence is preserved.
- Reset credentials for maxine.beck and for any account used on the host; rebuild the workstation from a trusted image if compromise cannot be ruled out.

Detection and prevention

- Alert on Office applications spawning `wscript.exe`, `cscript.exe`, or PowerShell.
- Alert on executables running from `C:\Windows\Tasks\` and `C:\ProgramData\`, and on scheduled-task creation with hidden PowerShell and registry-based payloads.
- Block or restrict macros in documents from the internet or email, and train staff on attachment-based lures, especially in HR and recruiting roles.

Evidence handling: Work only on evidence copies, record SHA-256 hashes of extracted artifacts, and never execute the payload on the Ubuntu analysis host.

9. Tools and Methods

Tool / plugin	Purpose
olevba 0.60.2	VBA macro extraction from the .doc
Volatility 3 Framework 2.28.2	Memory analysis
windows.pslist.PsList, windows.pstree.PsTree	Process listing and parent-child relationships
windows.cmdline.CmdLine	Process command lines
windows.netstat.NetStat	Network connections
windows.malfind.Malfind	Suspicious memory regions
windows.dlllist.DllList	Loaded modules
windows.filescan.FileScan	File-object references
Linux `strings`	Preliminary string extraction from the memory image